

2026-09-22-iptorrents-cookie-transcript-exposure

Incident 2026-09-22 — IPTorrents session cookie exposed in agent-session transcript

Revision: 1 **Last modified:** 2026-09-22T08:28:00Z **Reporter:** conductor (BOBA_API_TOKEN LAN-exposure remediation task) **Class:** credential-handling violation (§11.4.10 / §11.4.10.A — never print/log/echo a credential) **Severity:** MEDIUM — a private-tracker session cookie, not a system/infra credential; blast radius is limited to the IPTorrents account **Terminal state:** DISCLOSED to operator; ROTATION is an operator action (requires a fresh browser login/export), NOT performed by any agent

1. What happened

While verifying the BOBA_API_TOKEN write to .env (this session's LAN-exposure remediation task — see the sibling BOBA_API_TOKEN work in this session), the verifying subagent ran:

```
tail -8 .env | sed 's/BOBA_API_TOKEN=.*/[REDACTED]/'
```

intending to view only the newly-appended BOBA_API_TOKEN= block. .env's append point was near the end of the file, so the fixed 8-line tail window also captured one line *before* the intended append point:

```
IPTORRENTS_COOKIES='uid=...; pass=...'
```

That real credential value was printed into this session's tool-call output (and is therefore present in this session's transcript/session-log). The mistake was caught in the same verification pass; every

subsequent check used an exact line-range (`sed -n 'N,Mp'`) or a masked view, and no other secret was printed at any point before or after.

2. Provenance — this was a freshly-loaded, currently-active cookie

IPTORRENTS_COOKIES was one of five <TRACKER>_COOKIES values loaded into `.env` earlier in this same session via `scripts/load-tracker-cookies.sh`, sourced from `~/Downloads/cookies_iporrents.txt` (itself retrieved from `nezha.local`'s copy of this project, per the operator's own explicit instruction to pull genuinely-missing credential material from that host). The exposed value is therefore a **live, currently-valid session cookie**, not a stale/already-rotated one — the exposure has real (if narrow) blast radius until the operator rotates it.

3. Blast radius

- Scope: IPTorrents tracker session only. No system credential, no other tracker's credential, no `.env` var besides this one line was printed.
- `.env` itself was never made more exposed by this incident — the leak is into this session's own transcript/tool-output history, not into any tracked file, not into git, not into a log a third party could read without access to this Claude Code session.
- The four other freshly-loaded <TRACKER>_COOKIES values (`rutracker`, `nnmclub`, `rutor`, `kinozal`) were **not** printed — confirmed by the fixed 8-line tail window's actual content (only the one line immediately preceding `BOBA_API_TOKEN`'s append point was captured).

4. Why nothing caught it automatically

`sed/tail` are ordinary shell commands with no `.env`-awareness — nothing in this project's tooling scans an agent's own *verification* command output for credential-shaped content before it becomes visible in a session transcript (§11.4.10.A's pre-store leak audit governs values being **written to** tracked files / git history — it has no mandate over an agent's own read-side `cat/tail/grep` commands used to eyeball a file mid-task). This is a real gap: the discipline that protects *storage* does not protect *display*.

5. Remediation

- **Disclosed to the operator immediately** (this session, before any other work continued) rather than deferred to a summary.
- **Rotation is the operator's action** — an agent cannot generate a valid fresh IPTorrents session cookie; the operator must re-log-in (or trigger a session refresh) in a real browser, re-export a fresh Netscape cookies_iptorrents.txt to ~/Downloads/, and re-run scripts/load-tracker-cookies.sh --only iptorrents to load the fresh value. Until that happens, the exposed value remains the live credential in use.
- No attempt was made to auto-rotate, auto-regenerate, or otherwise guess a replacement value — that would itself be a §11.4.6 violation (fabricating a credential) and is explicitly out of scope for any agent.

6. What was deliberately NOT done

- The agent did **not** attempt to edit IPTORRENTS_COOKIES out of .env or blank it — doing so would break the currently-configured (still-valid, merely session-exposed) tracker integration without the operator's explicit instruction, which is itself a §11.4.122-class silent-removal risk this project forbids.
- This project's own tooling was **not** modified as part of this incident (a follow-up to add a credential-shaped-content scrub to ad-hoc verification commands is a reasonable hardening idea but is explicitly NOT claimed done here — recorded as an open follow-up, not shipped work, per §11.4.6/§11.4.197).

7. Open follow-up (tracked, not yet actioned)

A general-purpose “never let a bare tail/cat/head of .env (or any credential-bearing file) reach tool output uncontrolled” discipline — e.g. a small wrapper helper that always masks .env line content by variable name rather than printing raw values, available to any agent that needs to eyeball .env structure — is a legitimate hardening item for this project's tooling. Not implemented as part of this incident; recorded here so it is not silently lost (§11.4.197).